AFRICLUB

Production-readiness investigation

Current source • Archived work • Target-runtime gaps
Security, data, native/web and operating controls

NO-GO FOR A FULL FIVE-CLUB MIGRATED PRODUCTION RELEASE

27 September 2026 | AFRICLUB Google Drive workspace

The most urgent finding is anonymous write access affecting the source folder and sensitive-file examples. Contain access and re-establish source integrity before trusting a production build. No secret values were retrieved.

20	148	37	63
Key findings	Actionable tasks	Original QA items retained	Evidence / research entries

Internal working report. Source findings and evidence are separate from production verification. No source fixes, sharing changes, credential changes, migrations or deployments were performed.

Reading guide

Read the executive decision and security findings first. Use the workbook to assign work, attach evidence and track gates; do not mark a historical test as a current release approval. The original QA checklist is preserved separately, not silently rewritten.

1. Executive decision
2. Scope, method and evidence limitations
3. The actual repository state
4. Critical exposure and trusted-source recovery
5. Installed-source and integration findings
6. Freshly reproduced public-reader failures
7. Build, CI and software supply chain
8. Backend migration and data architecture
9. Authentication, privacy and role lifecycle
10. Payments, fulfillment and exception operations
11. Native readiness: Android and iOS are not interchangeable
12. Public web, admin/PWA, design and accessibility
13. Five-club, commercial and country readiness
14. Backups, operations, observability and economics
15. Recommended release strategy and gates
16. Task register and accountable completion
17. What this audit did and did not do

Appendix A — Complete findings register
Appendix B — All 148 identified task titles and prerequisites
Appendix C — Source and primary research register

Evidence key

E: current source or metadata. H: execution described by dated repository documents. X: fresh isolated/static analysis. R: primary external guidance. Bracketed source codes resolve in Appendix C and the workbook Sources sheet.

Important limit

This is a targeted deep investigation, not an exhaustive penetration test or a live-infrastructure certification. The source itself lists substantial acceptance work still open. The current sharing condition also means transfer hashes are not an independent proof of trusted provenance.

1. Executive decision

Decision: NO-GO for a full five-club Cloudflare production release. The workspace contains valuable legacy functionality, detailed QA records and increasingly careful isolated migration components. It does not yet demonstrate one trusted, integrated, target-runtime-tested release candidate. This conclusion is about the requested release, not a claim that all existing legacy services are down. [E02, E04, E05, E18, E19]

The most urgent new finding is not missing feature code: fresh permission metadata returned **anyone / writer** for the AFRICLUB folder, a website .env.local file and the Android upload keystore. Their contents and whether any credential is live were not inspected. No unauthorized access or compromise is proven. Nevertheless, this is a critical exposure and integrity condition that must be contained and investigated before a production build trusts this workspace. [E01, R01]

A second decisive issue is source convergence. Revised files, original files, partial integrations and complete archives coexist. The actual public staging configuration selects the original reader; that reader still exhibits freshness and media-integrity gaps in isolated tests. The operator console instructions refer to missing entrypoint/configuration files, and its current handler calls a publisher method absent from the current named wrapper. The iOS recovery code is preserved in an archive but was not observed in its intended native source folder. **Saved is not the same as installed; installed is not the same as deployed.** [E13-E17, E28, E29, X01]

The recommended order is: contain access; establish a trusted canonical checkout; reconcile all patches and contracts; repair release gates; prove an end-to-end pilot; complete operational and country/platform acceptance; then perform a separately approved single-writer cutover. Stop adding more disconnected candidate modules until the first integrated journey is reproducible. The shared monorepo and useful tested components should be preserved rather than rewritten. [E02, E26, H02]

The accompanying register contains **148 actionable tasks across 14 workstreams**, including six P0 containment/trust tasks, 133 P1 affected-release prerequisites and nine P2 improvement tasks. It records proposed owner roles, dependencies, actions, acceptance evidence and source links. These priorities are this audit's assessment, not externally certified ratings. The existing **37-item QA checklist is preserved verbatim and cross-mapped**, with its three checked and 34 unchecked source statuses left intact. No readiness percentage is assigned because route, object and release-scope denominators are not reconciled. [E04]

2. Scope, method and evidence limitations

The requested basis was the current AFRICLUB Google Drive workspace. I traversed scoped source, architecture, release, governance, CI, web, native and Cloudflare directories; read critical current files; downloaded selected source bytes for reproducible inspection; compared the installed structure with documented candidate integrations; and researched primary platform and regulatory guidance. The evidence register contains 63 repository, metadata, execution and primary-research entries. It is an evidence index, not a count of files exhaustively audited.

Evidence is separated into four categories. **Current source/metadata** supports what is presently in the inspected Drive locations. **Repository-reported history** supports what dated reports say was executed; those tests were not all rerun here. **Fresh isolated probes** support narrowly reproduced behavior of exact downloaded source. **External research** describes platform constraints and requirements, not the state of your accounts or deployments.

This is a targeted deep source-and-readiness investigation, not a full line-by-line audit of every archive, an independent penetration test, a legal opinion for five jurisdictions, or a certification of live infrastructure. Broad Drive listings can be bounded; absence conclusions are restricted to the specific scoped directories inspected. No public staging endpoint, real payment provider or customer account was exercised. Sensitive-file contents were deliberately not opened.

The connected GitHub read for the repository referenced in existing evidence returned HTTP 404. That does not establish that the repository was deleted: access, naming and connector installation may differ. Current hosted CI, branch/environment protections and the historical billing explanation therefore remain unverified. [E31, H03]

The local Node runtime was 22.16.0. It was used for isolated reader/validator probes, not a production web build. Fresh source pins are Flutter **3.44.9**, Node **22.23.2**, npm **12.0.2**; the workspace minimum remains Dart >=3.10 and Flutter >=3.38. Dart, Flutter and Wrangler were unavailable in this audit environment. No full application build, native device test, real D1 batch or current vulnerability scan is claimed. [E02, E09, E30]

3. The actual repository state

The useful architecture remains a Melos workspace with five thin club shells, shared core/data/feature packages, a common module registry, club configuration packages, a public/member website and an administrative PWA. The registry still protects the internal mobile-admin capability behind a compile-time switch; runtime club flags cannot simply turn it on in a consumer build. Those are strengths worth retaining. [E02, E03, E26]

The workspace now has at least three distinct implementation layers: the existing Supabase-backed application, new disabled Cloudflare service candidates, and archives/revised siblings containing changes not necessarily selected by runtime configuration. A release manifest must identify which version owns each route and operation. The folder's cache/build directories do not by themselves prove that generated files are tracked in Git; cleanup must inspect tracking before removal. Recovery archives and financial evidence are not disposable caches.

The dated September 25 inventory recorded **197 tables, 342 functions, 354 policies and 198 triggers**. It also recorded 18 local function entrypoints and 18 deployed functions with different memberships, six active scheduled jobs and hundreds of literal Supabase calls. These figures define a significant behavior/security migration, not merely eighteen JavaScript ports. They must be refreshed from an authorized consistent source snapshot before cutover. [H01]

The small canonical disposition CSV currently has seven aggregate rows. It is useful as a high-risk reminder, but cannot establish a decision for every source object. Larger inventories in archives must be reconciled into one maintained per-object register. An unresolved function, policy, relation or job must not be deleted merely because it lacks a Cloudflare mapping. [E27, H01, H02]

The new payment module is explicitly restricted to isolated-staging, with disabled switches and placeholder database/principal configuration. Turning it into a production writer is not safely accomplished by changing one Boolean: source history, authorization, actual target SQL behavior and governance must be completed first. [E19, E20]

4. Critical exposure and trusted-source recovery

F01 — P0: anonymous writer access and sensitive artifacts. Permission metadata for the root and two sensitive-file examples returned type=anyone, role=writer, and allowFileDiscovery=false. The last flag concerns search discovery, not a private access boundary. The website environment file and Android upload-keystore filename were visible; no secret values were extracted, downloaded into the audit pack or used. [E01, R01]

The security lead and owner should first restrict access, preserve available audit history and review all inherited/item permissions. They should then privately identify active credentials and signing material, assess exposure, rotate/revoke what is actually affected, and test service continuity. A filename alone does not tell us whether an environment value is a public key, expired secret or production secret; each requires classification. An upload key and an app-signing key have different recovery consequences, so preserve certificate lineage and use the appropriate Play App Signing process rather than indiscriminate replacement. [R15]

F02 — P0/P1: the evidence itself lacks an independent trust boundary. Checksums saved beside publicly writable source are valuable transfer checks, but a party able to alter source could also alter its local manifest. The previous successful archive readback therefore proves preservation of the uploaded bytes, not that all bytes are trusted, approved or installed. Establish a clean Git baseline, review diffs, inspect relevant history and retain release attestations in a separately protected location.

Immediate task sequence: SEC01-SEC05 and SRC01, followed by secret/history scanning, role cleanup and source reconciliation. This audit does not change access or credentials. It records the condition and creates sanitized reports only. Repository review and evidence generation are not authorization to deploy, sign a release, contact real payment recipients or destroy data.

5. Installed-source and integration findings

F03 — P1: canonical integration is incomplete.
cloudflare/rayon-public/wrangler.staging.jsonc still selects src/index.mjs. The selected file reads the legacy source_records projection. New immutable publication files and a revised reader sibling exist, but file presence does not connect them to the selected runtime. Integrate the reviewed canonical reader, import manifest, active snapshot and authorized publisher together. [E13, E14]

F04 — P1: the console handoff is internally inconsistent. CONSOLE.md specifies wrangler.console.staging.jsonc and src/console-worker.mjs; neither was found in the inspected root/src listings. A console-handler.mjs is present, but it requires PUBLIC_SOURCE_PUBLISHER.session. The inspected authorized publisher wrapper exposes review, publish, head and publication, not session. This is a concrete contract/wiring gap in the observed files; it is not proof that every archived console variant is defective. [E15-E17, E29]

F05 — P1: boundary-validation remediation did not reach the canonical validator. The exception registry exists, yet the current validator does not read it. An isolated minimal Git fixture passes; adding either the exact current migration plan or exact current inventory causes an unsupported-token failure. The reproduced conflict must be repaired in the canonical path invoked by CI. Preserve negative cases that detect prohibited runtime products; do not fix it by disabling enforcement or excluding all documentation. [E11, E12, X02]

F06 — P1: native delivery is partly archive-only. The inspected native directory lists Android, not iOS. Batch 12 is preserved in the conversation archive; this does not establish installation into the native source path or a compiled Apple build. Current Android documentation explicitly says the host is not registered or Android/Flutter-compiled. Reconcile all native sources with their build registration and final binaries. [E22, E28]

Recommended source acceptance rule: a change is implemented for release only when the canonical file, its selected entrypoint, its dependencies, migration state, caller and actual target test agree. The task register's SRC01-SRC10 workstream establishes that rule without throwing away historical versions.

6. Freshly reproduced public-reader failures

I ran four synthetic, no-network cases against the exact downloaded public-reader bytes. The source SHA-256 is recorded in the evidence pack. These are controlled code-behavior probes, not production incidents or a load test. [X01]

The stale control behaved correctly: with the newest source capture 72 hours old, the JSON route returned 503 source_stale. However, when an unrelated record supplied a recent global maximum, an older news projection was accepted with HTTP 200. This follows from using the newest timestamp anywhere in source_records as the freshness authority. The operational defect matters when partial refreshes can coexist; it is not evidence that a particular live import already did so.

Media requests returned HTTP 200 without executing the source freshness query, because media routing occurs before the JSON freshness gate. A separate media fixture returned HTTP 200 for incorrect bytes of exactly the expected length. The metadata had a SHA-256, but the active code checked size and did not validate the bytes it served. No real customer media was altered. [E13]

Repair this as a publication contract, not a timestamp patch: import a complete candidate, verify required tables and object hashes, seal it, approve it and atomically change active_snapshot_id. Bind reads to one approved version. Use content-addressed immutable media keys or equivalent served-byte integrity controls. Define whether media follows snapshot freshness or a separately governed rights/withdrawal policy, and test cache invalidation. [R06]

The public reader also needs representative volume tests for whole-source queries and media metadata assembly. Fixed output limits do not alone prove a bounded database scan. PUB01-PUB09 covers integrity, withdrawal, indexed projections, canonical hosts and cross-club publishing.

7. Build, CI and software supply chain

The current CI has meaningful existing database, Flutter and web jobs. The problem is not that CI was never written; it is that the inspected workflow does not explicitly run the newly added Cloudflare candidate suites, and its native artifact jobs are Rayon-centric. A five-club/two-platform release requires ten artifact identities, even where shared logic tests are legitimately reused. [E06]

F07 — P1: a deployment path is not visibly coupled to acceptance. The standalone web workflow installs dependencies, runs dependency checks, builds OpenNext and deploys. It does not contain a typecheck step, a needs relationship to the main QA workflow, or a declared protected environment. Meanwhile next.config.ts sets ignoreBuildErrors: true. This combination permits a source-level build/deploy path without a demonstrated mandatory typecheck. External GitHub controls might mitigate it, but they were not readable here and cannot be assumed. [E07, E08, E31]

Next.js explicitly documents that ignoring type errors is dangerous unless checking occurs elsewhere before deployment. Make all push/manual release routes consume the same previously tested artifact and require environment approval. A deliberately invalid TypeScript fixture must be unable to deploy by any path. Pin third-party Actions to reviewed commit SHAs and reduce permissions. [R02-R04]

Static manifest/lock comparison found no top-level declaration mismatch and 1,107 lock entries. The resolved top-level versions are recorded in the evidence JSON. This was not npm audit, installation or an advisories refresh. The repository's September dependency-remediation results remain useful historical evidence, not a current zero-vulnerability assertion. [E09, E10, H03, X03]

The same distinction applies to historical test totals. Do not sum successive batch totals into a platform coverage figure. Repeated suites, different source hashes, mocks, portable language tests and true target-runtime tests measure different things. CI01-CI10 establishes the reproducible candidate and supply-chain controls.

8. Backend migration and data architecture

D1 can serve suitable transactional workloads, but PostgreSQL policies/functions/triggers do not migrate by syntax substitution. Explicitly map every authorization and business invariant. Preserve the intent of pgTAP tests as replacement contract tests, including negative tenant cases, mutation-time revocation, uniqueness, rollback and historical receipt recovery. [H01, H02, E19]

Cloudflare documents a 10 GB maximum for a paid D1 database and serial query execution per database. Parameter, query-size and duration limits also constrain imports and large mutations. Test the actual schema and match-day workload before deciding database boundaries. The current shared allocation database is intentional: partitioning it by club would break its global provider-reference uniqueness unless a separate proven global authority replaces it. [R05, E19]

A D1 batch can roll back its contained statements; that does not make an identity database and an allocation database one transaction. The gateway's own documentation acknowledges a revocation race around checkout. Define the accepted command boundary and test it. A post-write identity failure must yield an uncertain outcome, not a claim that the write was rolled back. More consequential financial commands need stronger explicit authorization semantics before activation. [R06, E18]

Keep D1 as the current target unless a measured fit or legal constraint justifies a reviewed change. A Workers-to-PostgreSQL design through Hyperdrive is a legitimate alternative to evaluate for complex transactional domains, not an instruction to undo the migration or silently retain Supabase. The choice needs an ADR covering security ownership, operations, residency, cost and consistency. [R23]

Hosting is a concrete constraint. The retrieved D1 documentation says databases do not run in Africa; optional location hints do not guarantee a preferred region. Rwanda's DPO says offshore personal-data storage requires NCSA authorization among other safeguards. Obtain a specific approved hosting/processing/backup arrangement before personal-data cutover; choosing an EU hint does not itself establish Rwanda compliance. [R07, R21]

9. Authentication, privacy and role lifecycle

The new identity and membership gateway work contains good boundaries: verified server-derived identity, fixed private service capabilities, rejection of caller-selected payer/price fields, minimized historical receipts and explicit unknown-outcome handling. Those are necessary but do not complete end-user identity migration or an administrator access model. [E18]

The priority gaps are protected native credential storage; safe signup/guest linking; phone-change, lost-phone and recycled-number handling; session refresh/reuse; logout and account switch; browser-specific session handling; and staff role enrollment, expiry, revocation and review. Checkout recovery markers are not a bearer-token store. Do not solve missing integration with local preferences, global credentials or a service-role fallback. [E18, E22]

The inspected native gateway rejects browser-origin/cookie transport intentionally. Preserve that boundary and implement a deliberate member/admin browser session design instead of weakening it to reuse an adapter. Test CSRF, origin handling, cookie attributes, stale sessions, export access and private cache separation. Select specific ASVS/MASVS requirements as verification obligations; referencing those frameworks is not certification. [R11, R12]

OTP handling needs actual provider acceptance testing as well as code tests. A queue lease or provider acceptance receipt is not proof of delivery to a handset. Review legacy-versus-private delivery selection, signed callbacks, replay and abuse limits. For high-privilege staff actions, use a risk-appropriate stronger sign-in/step-up model; manually entered one-time codes are not phishing-resistant under the NIST benchmark. [R13]

Account deletion must progress beyond a pending request to actual downstream deletion or explicitly lawful retention, with status communicated accurately. Apple requires an in-app initiation route for apps with account creation; a transparent manual process can be acceptable, but deactivation alone is not equivalent to deletion. Reconcile records, media, backups, third-party services and devices. [R17]

10. Payments, fulfillment and exception operations

The isolated payment core is a substantive strength. It binds evidence to owner, club, amount, currency, provider and receiver; preserves a global consumed-transaction reference; commits membership renewal with ledger/receipt/outbox effects; retains administrative suspension; and distinguishes stored original receipts from present entitlement. Keep those invariants. [E19]

F08 — P1: authentic evidence is still an external trust boundary. A hash, parsed SMS or attestation-reference string is provenance, not proof of bank/mobile-money settlement. Implement authenticated management-gateway/provider intake with server-controlled tenant/merchant scope and replay resistance. The five supporter apps must not regain SMS collection responsibilities. Test the actual ingress and reconciler, not only seeded trusted receipts. [E04, E19]

F09 — P1: allocation is not complete business fulfillment. Contribution receipts deliberately keep businessTargetFulfilled: false; totals, rewards and referrals remain separate unfinished behavior. Tickets, stock, refunds, group contributions, gate scanning, Wallet lifecycle and their authoritative state transitions require completion or explicit exclusion from an initial release. An outbox acknowledgement is not proof that an external notification or pass was delivered. Cloudflare Queues is at-least-once, so consumers need idempotent effects and dead-letter recovery. [E19, R09]

F10 — P1: safe rejection needs a usable exception path. The conservative local handoff blocks uncertain attempts; that prevents one class of duplicate action but can strand a legitimate user. Expiry/cancellation does not prove a transfer never happened. Implement server-side unresolved-operation discovery, late-payment matching, maker/checker exceptions, refund requests and confirmed refunds. Keep immutable history and use compensating records; never delete a consumed-reference claim merely to retry.

Before migration, reconcile all historical provider references across every club and business target. Before release, reconcile actual provider statement to evidence, allocation, target outcome, refund and exception totals. A correct transaction on an incomplete history can still admit a duplicate payment. PAY01-PAY12 and DOM01-DOM10 cover this end-to-end control chain.

11. Native readiness: Android and iOS are not interchangeable

The Android recovery engine has useful portable test evidence and intentionally conservative failure semantics. Its current runbook nevertheless says the actual host is not registered, Android/Flutter compilation and Keystore/device acceptance have not run, and the component stores markers rather than credentials. Treat these statements as explicit open gates, not minor release paperwork. The iOS source remains archive-only in the inspected native path. [E22, E28]

Complete the real platform build and registration once in shared infrastructure; do not copy independent implementations into five shells. Verify Keychain/Keystore policies, locked state, engine/isolate death, durability, key invalidation, app update, backup restoration and complete data loss on physical devices. The local installation lock cannot coordinate another handset. Server authority must reconcile unresolved operations after reinstall or device replacement. [R12, R24, E22]

F11 — P1: the iOS USSD handoff requires a product correction or proof. The current optional bridge accepts both Android and iOS and opens a tel: URI containing a star/hash USSD code. Apple's archived phone-link documentation states that strings containing * or # are not dialed. This is documented compatibility risk, not a newly executed modern-iPhone failure. Do not assume URI encoding bypasses the restriction. Verify real devices/carriers and provide an explicitly approved supported alternative or truthful unsupported state. [E21, R14]

The confirmation UI must display the exact reviewed fields, require a separate foreground action and invalidate review on backgrounding, logout, account switch or route exit. Returning from a dialer is never payment success. Test dual SIM and missing handler behavior independently on Android. Ten current club/platform identities and signed-device acceptance are needed for the whole five-club release; a four-club simulator checkpoint does not close that matrix. [E04, E22]

12. Public web, admin/PWA, design and accessibility

The repository records real earlier work on UI, member recovery, public content, storage checks and browser cases. Those achievements should be retained with their exact source hashes. The old owner approval covers the presented four-club artifacts, not every later membership heading, native bridge, new console or Costa do Sol surface. No current screen-by-screen visual or human accessibility review was performed by this audit. [E04, H05]

Resolve the selected revolut-design authority and keep repository documents as its product adaptations. A shared design system should provide consistent semantic controls, focus, status and typography, without forcing a dense operator workspace into a consumer mobile layout. Validate both task usability and reference fidelity; golden equality alone answers neither question. [E03, E04]

The required UI matrix includes published/unpublished, empty, stale, offline, denied, expired, pending, failed, unknown and completed states, across role, club, platform and relevant viewport. Current central route-state and evidence-bundle registers are empty despite evidence elsewhere. Populate or explicitly replace those maintained registers with a source-bound index; do not call all historical captures a final denominator. [E24, E25]

For web/PWA, test installed versus browser mode, stale app shells, old tabs, preserved drafts, storage denial/quota, private-cache exclusion, logout/account switch and safe update prompts. Never replay old queued money mutations automatically. For admin, include actual cross-club write/readback, stale edit conflict, partial bulk failure, filters/pagination and auditable destructive review. [E04]

Use WCAG 2.2 AA criteria where applicable plus human keyboard/VoiceOver/TalkBack tasks. Measure public field performance separately from local Lighthouse: Core Web Vitals use the 75th percentile and targets of LCP <=2.5 seconds, INP <=200 milliseconds and CLS <=0.1. A historical 0.89 versus 0.90 Lighthouse case remains a diagnostic failure, not a current field measurement. [R19, R20, E04]

13. Five-club, commercial and country readiness

A supported club shell is not necessarily onboarded, legally authorized, configured with a merchant, published to stores or operationally supported. Keep those states separate. The dated inventory identified Rayon as the active/onboarded tenant; the repository still supports all five club products and explicitly lists Costa do Sol release inputs as outstanding. Do not delete the other shells or claim they are release-ready because shared tests pass. [E03, H01]

For each club, obtain a source-backed register of legal operator, club authorization, publisher account, package/bundle IDs, verified merchant, currency/country, receiver, support contacts, domain/deep links, brand assets and permitted feature set. The canonical IDs and slugs must be preserved; the reserved Costa tenant ID needs collision and source-import verification rather than automatic acceptance.

Privacy, consumer, tax, payment and reward obligations require separate Rwanda, Burundi, Zambia, DRC and Mozambique applicability decisions. This audit verified relevant Rwanda offshore-storage guidance and the existence of Zambia's official controller/processor registration materials, but did not obtain a complete current legal opinion for all five jurisdictions. The register explicitly leaves the remaining country reviews open. Do not infer that a digital fan club is a licensed deposit-taking institution, or that processing a contribution automatically requires or avoids a particular financial licence. Analyse the actual contractual funds flow. [R21, R22]

Store billing depends on the actual benefit: physical event attendance/goods and digital content/services cannot be classified solely by calling the product a membership. Apple also distinguishes template providers from the provider of an app's content; review each club's submission arrangement and unique experience. This is not a conclusion that white-label apps are categorically rejected. [R16]

The current Predict decision does exist: it establishes a conservative no-debit/free-entry contract pending accountable approval of an alternative. Reconcile historical 100-FET/pool descriptions against that gate, preserve history, and test all client/server routes. Review loyalty/prize and payment rules before activation; no regulatory approval is created by a source file or test result. [E23, R18]

14. Backups, operations, observability and economics

The September 25 continuation reports a successful database archive restore drill. It also says the restored archive plus separately recovered cron segments is not a transactionally consistent final backup, and eight AFRICLUB Storage originals were still inaccessible. Do not collapse this into either "no backup exists" or "backup is complete." The successfully replayed public-media set is a different scope. [H01]

Supabase's documentation confirms that database backups do not include Storage object bytes. A retirement-ready backup must cover required data, media originals, schema, configuration, secrets recovery procedures and outstanding events, with rights and integrity manifests. Measure restore time and permitted data loss, and demonstrate actual application behavior after restoration. Keep originals and historical financial claims; do not delete them as part of generic cleanup. [R10, H04]

Candidate configurations explicitly disable observability in inspected services. Production needs privacy-safe structured events, end-to-end correlation, actionable alerts, on-call ownership, queue/dead-letter dashboards, database capacity signals and operator recovery runbooks. This does not justify logging raw phone numbers, OTPs, tokens or provider payloads. Trace receipt, operation, tenant and event identifiers under an approved access/retention policy. [E18, E19]

Agree measurable availability, latency, source freshness, payment-confirmation and support objectives before load testing. Model normal, match-day and abusive traffic, including OTP costs, database reads/writes, object delivery, queue retries, builds and human exception handling. Pricing snapshots or cheap unit rates cannot substitute for a measured workload. The past provider quota and CI billing failures are historical indicators to investigate, not confirmed current outages. [H01, H03]

Operational safety includes truthful uncertainty. A service timeout cannot cancel a carrier action or a database commit already in progress. Incident response must reconcile accepted writes before traffic moves back. Define a cutover point of no return, old-client compatibility, recovery ownership and forward compensation instead of promising a blind rollback to an old database. [H02, H04]

15. Recommended release strategy and gates

Recommended strategy: convergence first, then a staged rollout. The best next engineering increment is not another isolated capability. It is one clean, trusted, integrated candidate whose read path, identity, checkout, native handling, evidence and operational outcomes can be demonstrated together.

G0 — Containment: remove anonymous access with owner approval, assess exposed credentials/signing assets and restore trusted-source provenance. No untrusted-source release build should proceed while this gate is unresolved.

G1/G2 — Canonical baseline and scope: reconcile all delivered changes, choose the actual repository/ref, approve the initial club/features and settle hosting, commercial and economic decisions. Preserve unfinished features behind both server and client controls.

G3 — Integration and build: repair canonical reader/console/validator contracts, pin toolchains and make every deployment depend on exact candidate tests. Demonstrate actual Worker and native builds, not syntax-only or desktop-language substitutes.

G4/G5 — Data and end-to-end behavior: reconcile identities, historical claims, media and role/security equivalents. Complete actual authenticated flows for the chosen scope, including provider evidence and usable unknown/late-payment operations.

G6/G7 — Operations and acceptance: validate SLOs, backup restore, security, accessibility, all enabled route/state cases, real devices and providers. Record independent reviewers and owner acceptance against the final hashes.

G8 — Controlled cutover: after separate approval, fence old writes, apply the final consistent snapshot/delta, reconcile, switch one writer, verify old-client behavior, and observe accepted transactions and support outcomes. An archive upload or source test does not authorize this action.

G9 — Retirement and expansion: retire old services only after the observation period, complete disposition and restorable evidence. Release additional clubs only after their own identity, merchant, legal, store and device gates pass.

A narrower initial release can be reasonable: for example, one club's approved public content while monetary capabilities remain unavailable. That requires explicit scope approval and the public integrity/security gates; it is not a shortcut to declaring the full platform complete. No implementation percentage or calendar estimate is supported by the unreconciled scope. Dependencies and evidence, not accumulated file or test counts, should determine the sequence.

16. Task register and accountable completion

The companion workbook is the execution instrument. **148 tasks** are organized into Security (8), Source convergence (10), CI (10), Identity (12), Payments (12), Business domains (12), Data (12), Publishing (10), Native (12), Web/PWA (10), UX/accessibility (8), Legal/platform (12), Operations (10) and Release (10).

Each task has a stable ID, priority, recommended owner role, explicit prerequisite IDs, required action, acceptance evidence, source references and original-QA crosswalk. All are open proposals to verify or implement the identified requirement; the audit does not assign named staff, run production changes or mark existing work complete by rewriting its status. Dependency references are validated and acyclic.

The **Original QA37** sheet retains the source wording and checkmarks. Three historical checked items concern a repaired SQL allocation path, scoped member-web recovery and editorial provenance. Their existing evidence is not erased. Their current candidate regression still needs verification, while the other 34 source items remain unchecked. Where older entries say four clubs/eight native builds, retain that historical text but expand the new acceptance matrix to five clubs/ten targets. [E04]

"All tasks" here means all actionable tasks identified by this investigation, including completing the missing route/object inventories. It is not a claim that no additional work can be discovered while reconciling previously unseen code, actual resource settings or a country-specific legal requirement. Any newly discovered blocker should receive a stable ID and be added without weakening an acceptance gate.

The first accountable outcomes should be SEC01-SEC05/SRC01, then SRC02-SRC06 and CI01-CI05. In parallel, LEG01-LEG05, DAT01-DAT03 and AUT01/AUT07 establish the decisions and authorities that downstream code cannot safely invent. The final release sign-off should remain NO-GO until the affected gates have actual evidence, not until a target number of tasks has been ticked.

17. What this audit did and did not do

Performed: current Drive traversal and targeted reads; permission metadata inspection; fresh source-byte hashing; four isolated reader probes; three isolated validator fixtures; static workflow and dependency-lock checks; primary research; source/task/evidence reconciliation; creation of the report and registers.

Not performed: source fixes or patch installation; permission/credential changes; fresh exhaustive repository export; full vulnerability/secret scan; hosted CI verification after the 404 response; full Flutter/Next.js or Apple/Android builds; real D1/Access/provider tests; physical-device or visual accessibility acceptance; live billing, payments, media mutation, migration, cutover or retirement.

The isolated probes reproduced expected controls and gaps; their purpose was diagnosis. A HTTP 200 in a fake-storage fixture is not proof of a live data leak, and a validator failure in a minimal Git fixture is not a hosted CI result. Older reported test totals remain historical, not newly executed tests in this audit.

The full report and task register should be treated as controlled internal material. They contain no retrieved secret values. Uploading them to the requested folder preserves the deliverables but does not fix the folder's access condition. The owner should protect that location before distributing source or security evidence further.

Appendix A — Findings register

Priority is this audit's assessment. Fresh source/metadata, historical reports and isolated execution are distinguished to avoid overstating confidence.

ID / priority	Finding and basis	Observed gap / verification limit	Response and task IDs
F01 / P0	Anonymous write and sensitive artifacts Fresh metadata	Root plus .env.local and upload keystore show anyone/writer. Contents/active keys and compromise not inspected. [E01,R01,R15]	Potential disclosure and code/evidence tampering; contain and investigate. SEC01-SEC08
F02 / P0	Trusted source not established Assessment from metadata + source structure	Mutable source, revised copies and co-located manifests cannot establish independent provenance. [E01,E02,E28,E29]	Recover clean trusted Git/ref before release builds. SRC01-SRC03
F03 / P1	Legacy public reader still selected Current source + configuration	Configured entrypoint reads source_records despite newer snapshot candidates. [E13,E14]	Integrate the actual reader/import/publisher/schema. SRC04,PUB02
F04 / P1	Public freshness and media gaps Fresh isolated reproduction	Global MAX timestamp accepts mixed freshness; media bypasses freshness and only verifies size. [E13,X01]	Bind complete snapshots and verify served media integrity. PUB02-PUB04
F05 / P1	Console contract and files inconsistent Current source + scoped listings	Required console worker/config absent; handler session call missing from named publisher wrapper. [E15,E16,E17,E29]	Converge selected contracts and prove real console journey. SRC05,PUB05
F06 / P1	Original boundary validator still conflicts Fresh isolated reproduction	Two exact migration documents rejected; separate exception registry not consumed. [E11,E12,X02]	Correct canonical scanner without loosening runtime boundaries. SRC06
F07 / P1	Deployment lacks demonstrated typecheck gate Current static source	Direct deploy flow plus ignoreBuildErrors; external protections not verified. [E06,E07,E08,E31,X03]	Couple all deployments to exact successful candidate checks. CI01-CI05
F08 / P1	New candidate suites not visibly in main CI Current static source	Main workflow lacks explicit candidate-module/host suite references and all-club artifact matrix. [E06,X03]	Add source-bound target-runtime CI coverage. CI05,CI06,CI10
F09 / P1	No final evidence or sign-off denominator Current registers + reported QA	Central route cells and bundles empty; sign-off blank; 34 of 37 source QA tasks unchecked. [E04,E05,E24,E25]	Reconcile case inventory and current candidate decisions. UX07,REL02-REL04
F10 / P1	Identity and financial authorization span databases Explicit current documentation	Gateway rechecks cannot atomically revoke an already committed checkout. [E18,R06]	Define and test operation-specific authorization/unknown semantics. AUT07,AUT12
F11 / P1	Provider evidence boundary incomplete Explicit source limitation	Private parsed evidence/hash is not actual settlement proof; authentic ingress remains required. [E04,E19]	Implement trusted management/provider/reconciler boundary. PAY01,PAY10

ID / priority	Finding and basis	Observed gap / verification limit	Response and task IDs
F12 / P1	Financial fulfillment and exceptions unfinished Explicit current module scope	Contribution totals/rewards/referrals, refunds and other domains remain incomplete; outbox lacks final consumers. [E19,R09]	Finish enabled domains, reconciliation, late/unknown outcomes and compensation. PAY05-PAY12,DOM01-DOM10
F13 / P1	Native code is not an installed verified app Current runbook + scoped listing	Android host unregistered/uncompiled; iOS absent from intended source folder. [E22,E28]	Integrate source and validate actual SDK/device builds. NAT01-NAT04
F14 / P1	iOS USSD compatibility is unproven Current code + archived Apple guidance	Bridge tries tel star/hash on iOS; Apple documents restriction. No new device test performed. [E21,R14]	Verify supported path and explicit alternative; never infer payment success. NAT05,NAT06
F15 / P1	Lost-state and credential storage not complete Explicit current module scope	Recovery markers do not protect tokens or resolve reinstall/new-device payment uncertainty. [E18,E22]	Separate protected credentials and server-authoritative recovery. AUT02,PAY05,NAT08
F16 / P1	Migration inventory and retirement map incomplete Current CSV + dated source inventory	Seven aggregate dispositions versus hundreds of source objects; deployed/local functions differ. [E27,H01,H02]	Refresh and approve every object, caller and replacement contract. DAT01-DAT07
F17 / P1	Final backup/media preservation incomplete Dated recovery record	Restore drill reported successful; final consistency and eight unrelated media originals remain unresolved. [H01,R10]	Complete consistent restore/reconciliation and object-byte recovery. DAT02,DAT08,DAT09
F18 / P1	Five-club release and legal conditions differ Current scope + dated onboarding status	Shell support is not onboarding/publisher/merchant/device acceptance; Costa prerequisites explicit. [E03,H01,R16,R21,R22]	Per-club release matrix and country/publisher decisions. LEG01-LEG12,REL08
F19 / P1	Hosting and operational acceptance unproven Current config + primary research	Staging-only gates/placeholders, disabled telemetry, non-African D1 locations. [E19,E20,R05,R07,R21]	Approve hosting; prove actual resources, alerts, capacity and recovery. LEG05,DAT07,OPS01-OPS10
F20 / P1	Economic, UI and acceptance drift Current governance + dated QA	Conservative Predict gate exists; historical debits and old visual approval cannot prove current acceptance. [E03,E04,E23,R18,R19]	Align actual enabled economics and independent visual/accessibility evidence. DOM08,DOM09,UX01-UX08

Appendix B — Complete task index

All 148 identified tasks are indexed here. The workbook and JSON/CSV contain detailed actions, acceptance criteria, recommended owner roles, source URLs and crosswalks. Dependency IDs are valid and acyclic. Additional tasks may emerge when the remaining inventories are reconciled.

Security containment (8)

ID	Priority	Task	Prerequisites
SEC01	P0	Restrict public-write access	None
SEC02	P0	Investigate potential exposure	SEC01
SEC03	P0	Revoke affected service credentials	SEC02
SEC04	P0	Protect signing identity	SEC02
SEC05	P0	Re-establish trusted source integrity	SEC01,SEC02
SEC06	P1	Separate secret and recovery storage	SEC03,SEC04
SEC07	P1	Scan source and history	SEC05,SEC06
SEC08	P1	Harden collaborator governance	SEC01

Source convergence and architecture (10)

ID	Priority	Task	Prerequisites
SRC01	P0	Create canonical release checkout	SEC05
SRC02	P1	Reconcile every delivered patch	SRC01
SRC03	P1	Resolve revised-file siblings	SRC02
SRC04	P1	Install the snapshot-reader integration	SRC03
SRC05	P1	Repair operator console composition	SRC03
SRC06	P1	Integrate governed boundary exceptions	SRC03
SRC07	P1	Resolve backend architecture decision	SRC01
SRC08	P1	Publish contract ownership map	SRC07
SRC09	P1	Enforce feature and tenant precedence	SRC08
SRC10	P2	Clean only disposable artifacts	SRC02,SEC06

Build and supply-chain gates (10)

ID	Priority	Task	Prerequisites
CI01	P1	Restore hosted CI visibility	SRC01
CI02	P1	Pin the complete toolchain	SRC01
CI03	P1	Gate every deployment path	CI01,CI02
CI04	P1	Remove implicit typecheck bypass	CI03
CI05	P1	Add candidate backend suites to CI	SRC04,SRC05,SRC06,CI02
CI06	P1	Build ten club-platform targets	CI02,SRC09
CI07	P1	Harden workflow dependencies	CI01,SEC06
CI08	P1	Refresh advisories and SBOM	CI02
CI09	P1	Seal artifact provenance	CI05,CI06,CI08
CI10	P1	Verify native and Worker toolchains	CI02

Identity and authorization (12)

ID	Priority	Task	Prerequisites
AUT01	P1	Model the identity migration	SRC08
AUT02	P1	Implement protected credential storage	CI10
AUT03	P1	Complete anonymous and signup flows	AUT01
AUT04	P1	Implement phone and lost-phone recovery	AUT01
AUT05	P1	Verify real OTP delivery	AUT01,OPS03
AUT06	P1	Eliminate unsafe legacy delivery defaults	AUT05
AUT07	P1	Specify cross-database revocation semantics	SRC07,AUT01
AUT08	P1	Complete refresh and logout integration	AUT02,AUT07
AUT09	P1	Implement staff authorization lifecycle	AUT07,SEC08
AUT10	P1	Secure browser sessions	AUT07
AUT11	P1	Complete export and deletion workflows	AUT01,LEG04
AUT12	P1	Threat-model all tenant boundaries	SRC08,AUT09,AUT10

Payment evidence and recovery (12)

ID	Priority	Task	Prerequisites
PAY01	P1	Define authentic evidence ingress	AUT09,AUT12
PAY02	P1	Reconcile historic transaction claims	DAT01,DAT02
PAY03	P1	Approve receiver and catalog mappings	LEG01,DAT02
PAY04	P1	Connect actual checkout clients	AUT08,AUT10,PAY03,NAT04
PAY05	P1	Recover lost local operation state	AUT07,PAY04
PAY06	P1	Resolve late and unknown payments	PAY01,PAY05,AUT09
PAY07	P1	Implement reversals and refunds	PAY06,LEG02
PAY08	P1	Prove one writer under cutover	PAY02,DAT07
PAY09	P1	Integrate durable effect consumers	DOM10,OPS03
PAY10	P1	Run real transactional acceptance	PAY01,PAY04,PAY08
PAY11	P1	Reconcile finance and operations	PAY07,PAY09,PAY10
PAY12	P1	Review ledger language and presentation	PAY10,DOM01

Complete retained business domains (12)

ID	Priority	Task	Prerequisites
DOM01	P1	Complete membership product	PAY10,AUT12
DOM02	P1	Complete initiative contributions	PAY01,LEG03
DOM03	P1	Complete group contribution flows	DOM02,AUT12
DOM04	P1	Finish ticket inventory and issuance	PAY10
DOM05	P1	Complete gate redemption	DOM04,AUT09
DOM06	P1	Complete Wallet pass lifecycle	DOM04,OPS03
DOM07	P1	Complete shop transactions	PAY07,PAY10
DOM08	P1	Reconcile Predict economic contract	LEG03,SRC09
DOM09	P1	Complete prediction settlement	DOM08
DOM10	P1	Define event schemas and consumers	SRC08
DOM11	P1	Verify football content completeness	PUB01

ID	Priority	Task	Prerequisites
DOM12	P2	Retire only classified dead capability	DAT03,SRC09

Data migration and recovery (12)

ID	Priority	Task	Prerequisites
DAT01	P1	Refresh authoritative source inventory	SRC01,SEC06
DAT02	P1	Create immutable migration snapshot	DAT01
DAT03	P1	Expand per-object disposition register	DAT01,SRC08
DAT04	P1	Port the deployed function set	DAT03
DAT05	P1	Port or retire scheduled jobs	DAT03,OPS03
DAT06	P1	Translate security contracts	DAT03,AUT12
DAT07	P1	Prove target database fit	SRC07,DAT06
DAT08	P1	Recover all original media	DAT01,SEC06
DAT09	P1	Automate backup and restore drills	DAT02,DAT08
DAT10	P1	Reconcile identifiers and accounting units	DAT02,PAY03
DAT11	P1	Design privacy-aware archival retention	LEG04,DAT09
DAT12	P1	Prove rollback after new writes	PAY08,DAT09

Public content and publishing (10)

ID	Priority	Task	Prerequisites
PUB01	P1	Bind content to approved sources	SRC08
PUB02	P1	Publish complete immutable snapshots	SRC04,PUB01
PUB03	P1	Verify media bytes and policy	PUB02
PUB04	P1	Define freshness and withdrawal	PUB02,PUB03
PUB05	P1	Complete operator API and UI integration	SRC05,AUT09
PUB06	P1	Verify editorial confirmation and recovery	PUB05
PUB07	P2	Scale read queries and pagination	DAT07,PUB02
PUB08	P1	Prove all-club public routing	SRC09,LEG01

ID	Priority	Task	Prerequisites
PUB09	P1	Complete public web acceptance	PUB08,UX01,WEB01
PUB10	P1	Review content ingestion and AI boundaries	PUB01,AUT09

Native apps and platform completion (12)

ID	Priority	Task	Prerequisites
NAT01	P1	Install reviewed native candidate source	SRC02,SRC03
NAT02	P1	Compile real native hosts	NAT01,CI10
NAT03	P1	Validate encrypted recovery on devices	NAT02
NAT04	P1	Register shared native components	NAT03,AUT02
NAT05	P1	Design and test iOS payment fallback	NAT04,PAY03
NAT06	P1	Test Android carrier and SIM behavior	NAT04,PAY03
NAT07	P1	Wire accessible review and lifecycle	NAT04,UX02
NAT08	P1	Handle update and reinstall recovery	PAY05,NAT03
NAT09	P1	Prove ten signed identities	CI06,SEC04,LEG01
NAT10	P1	Verify native permissions and deep links	NAT09,AUT12
NAT11	P2	Measure native performance	NAT04,OPS02
NAT12	P1	Complete authenticated device journeys	NAT05,NAT06,NAT07,PAY10,DOM01

Web and admin PWA (10)

ID	Priority	Task	Prerequisites
WEB01	P1	Reconcile public/member/admin route matrix	SRC08
WEB02	P1	Complete admin business operations	AUT09,WEB01
WEB03	P1	Secure public/member caching	AUT10,WEB01
WEB04	P1	Handle PWA version and draft lifecycle	WEB03
WEB05	P2	Tighten CSP safely	CI04,WEB01
WEB06	P1	Complete server error and conflict UX	PAY04,AUT10
WEB07	P1	Verify uploads and exports	AUT12

ID	Priority	Task	Prerequisites
WEB08	P1	Verify responsive operator workspaces	WEB02,UX02
WEB09	P1	Run real Cloudflare web runtime	CI03,CI09,WEB01
WEB10	P1	Approve browser support and installed PWA	WEB04,WEB08,WEB09

Design, content and accessibility (8)

ID	Priority	Task	Prerequisites
UX01	P1	Unify design authority and adapters	SRC03
UX02	P1	Run independent accessibility tasks	UX01
UX03	P1	Refresh visual source comparisons	UX01,NAT04,WEB01
UX04	P1	Validate state and recovery copy	PAY12,WEB06
UX05	P2	Decide locale and market support	LEG01,UX04
UX06	P2	Test usability with representative supporters	UX02,NAT12,WEB10
UX07	P1	Reconcile evidence registers	UX03,CI09
UX08	P1	Verify media and brand rights	PUB01,LEG01

Country, commercial and platform compliance (12)

ID	Priority	Task	Prerequisites
LEG01	P1	Approve five-club operating entities	SEC02
LEG02	P1	Classify each payment product	LEG01
LEG03	P1	Approve FET and prediction rules	LEG02
LEG04	P1	Approve privacy roles and retention	LEG01
LEG05	P1	Resolve Rwanda offshore storage	LEG04,SRC07
LEG06	P1	Complete Zambia compliance review	LEG04
LEG07	P1	Complete Burundi compliance review	LEG04
LEG08	P1	Complete DRC compliance review	LEG04
LEG09	P1	Complete Mozambique compliance review	LEG04
LEG10	P1	Approve white-label store submission model	LEG01,UX08

ID	Priority	Task	Prerequisites
LEG11	P1	Complete store privacy and deletion declarations	AUT11,NAT10,LEG04
LEG12	P1	Approve provider and content contracts	LEG01,LEG02

Reliability and operational readiness (10)

ID	Priority	Task	Prerequisites
OPS01	P1	Assign operational service ownership	SRC08,LEG01
OPS02	P1	Approve measurable SLOs and capacity	SRC07
OPS03	P1	Implement privacy-safe telemetry	LEG04,OPS01
OPS04	P1	Operate retries and dead letters	OPS03,DOM10
OPS05	P1	Measure match-day peak behavior	DAT07,OPS02
OPS06	P2	Model operating costs and quotas	OPS05,AUT05
OPS07	P1	Exercise disaster recovery	DAT09,OPS03
OPS08	P1	Harden production configuration	SRC08,CI07,LEG05
OPS09	P1	Run application security assessment	AUT12,WEB09,NAT12,OPS08
OPS10	P1	Rehearse operator and customer support	PAY06,OPS01,DOM05

Release acceptance and cutover (10)

ID	Priority	Task	Prerequisites
REL01	P1	Choose a minimal release scope	LEG01,SRC09
REL02	P1	Freeze the final candidate	CI09,UX07
REL03	P1	Close the original QA checklist	REL02
REL04	P1	Complete independent go/no-go review	OPS09,OPS10,REL03
REL05	P1	Run controlled production rehearsal	DAT12,PAY11,REL02
REL06	P1	Approve and execute single-writer cutover	REL04,REL05
REL07	P1	Observe and prove stability	REL06
REL08	P1	Release each additional club independently	REL07,NAT09,LEG06,LEG07,LEG08,LEG09

ID	Priority	Task	Prerequisites
REL09	P1	Retire legacy services deliberately	REL07,DAT03,DAT09
REL10	P2	Maintain post-release control cadence	REL07

Appendix C — Evidence and sources

Checked 27 September 2026. The 63 entries include current files, specific metadata/listings, execution evidence and 24 external primary sources. URLs and IDs identify the basis, not production validation.

E01 — Drive permission metadata
Fresh connector metadata
Root, web .env.local and Android upload-keystore.jks returned anyone/writer. Contents, active credentials and compromise were not inspected.
evidence/permission_observations.json

E02 — Workspace manifest
Current Drive source
Five shells; Dart >=3.10, Flutter >=3.38, Melos 8.1.0; current scripts.
https://drive.google.com/file/d/1NBjccCUL0GExYKlWVsGptSv3TttePFa7/view

E03 — Repository README
Current Drive source
Canonical five-club scope, tenant separation, Costa do Sol prerequisites.
https://drive.google.com/file/d/1W-wB0714GR2PtTb01XldFYbQcFhL_1AC/view

E04 — Full-stack QA plan
Current Drive source
37-item checklist; three checked historical closures and 34 unchecked tasks; source narrative contains four/five-club drift.
https://drive.google.com/file/d/1GcYfaSWxQqQBw2OMLoX1Q_qZCWPd5-wT/view

E05 — Release sign-off template
Current Drive source
Candidate and accountable sign-off fields remain blank.
https://drive.google.com/file/d/1tMWvEOR1NtOKeLcOzacrMepubzmxr_lf/view

E06 — Main CI workflow
Current Drive source
Existing Flutter/Supabase/web controls; release build jobs concentrate on Rayon; new migration suites not explicitly referenced.
https://drive.google.com/file/d/1vza_RNiaP7bOgavHdtYifYUk4uYBoOXM/view

E07 — Standalone web deployment
Current Drive source
Direct build/deploy job lacks a typecheck step and declared job/environment dependency in this file. External protections not verified.
https://drive.google.com/file/d/1JriJdKI5ZI66Zb0tcrD49U8vIXdk9_su/view

E08 — Next configuration
Current Drive source
ignoreBuildErrors true; security headers present; inline script allowance in production CSP.
https://drive.google.com/file/d/1ylTZbAFeURan9Rk_8oJwsqd1YOKJDtAM/view

E09 — Web manifest
Current Drive source
Node >=22.22.2<23, npm >=12<13 and packageManager npm@12.0.2; scripts and dependency constraints.
https://drive.google.com/file/d/1P7Dd9dMO4dT35M-va4qQIYwTgLVFUeCy/view

E10 — Web lockfile
Current Drive source
Static manifest/lock agreement; 1,107 entries; this is not a current advisory audit.
https://drive.google.com/file/d/1VUEo8hN8J0fs0WNG9JAPTG6O0VDtudWi/view

E11 — Original repository boundary validator
Current Drive source
Current canonical validator rejects legacy tokens in inventory docs; does not consume exception registry.
https://drive.google.com/file/d/1N23TLa4JwiI46dPwiWV3ODcISwmOJBRX/view

E12 — Legacy reference exceptions
Current Drive source
Three path/hash exceptions exist separately; original validator integration is absent.
https://drive.google.com/file/d/1Q3q5yo7o0uB4_Dt_6hhBfdITNMBa7c6b/view

E13 — Current public reader
Current Drive source
Reads legacy source_records; global MAX timestamp; media precedes freshness and checks size without served-byte hash.
https://drive.google.com/file/d/11HjHNGCFck0SiQGNHOWljw4Q-nxeMIPw/view

E14 — Public staging configuration
Current Drive source
Still selects src/index.mjs, not a revised sibling.
https://drive.google.com/file/d/1H03mwkVQ6Rb8GQPIYMzFwSAcoVHNfLe2/view

E15 — Authorized publisher entrypoint
Current Drive source
Exports review, publish, head and publication; no session RPC.
https://drive.google.com/file/d/1N64ubm9zvPe9X06KkhPKXlbD7gD3uPCH/view

E16 — Console integration instructions
Current Drive source
Names console config/worker not found in current listed locations; distinguishes offline DOM from real Access tests.
https://drive.google.com/file/d/1xZTMg97Hq6fVXwtOgwZZghB8x38wPeCA/view

E17 — Console handler
Current Drive source
Calls PUBLIC_SOURCE_PUBLISHER.session, absent from the current named publisher wrapper.
https://drive.google.com/file/d/1fgnPtcoK0sc6T5JVQxg8vAonL1QkuwAJ/view

E18 — Supporter membership gateway
Current Drive source
Native-only bearer gateway; cross-database revocation limitation; no five-shell installation.
https://drive.google.com/file/d/1ZMOX3aVmWujKCYV_YahrkQ5NPbFXuY7h/view

E19 — Payment allocation module
Current Drive source
Atomic membership evidence core; contribution not fulfilled; provider trust, historic claims, downstream effects and cutover unfinished.
https://drive.google.com/file/d/11c2iijJkMgVqUIhC9JivYi8vxb5prAsr/view

E20 — Allocation runtime policy
Current Drive source
Runtime refuses non-isolated-staging environment; strict evidence grammar.
https://drive.google.com/file/d/1xBC0GmbHRGxECDyg0sSoYLxCLc5B19DJ/view

E21 — Native external dialer
Current Drive source
Opt-in Android/iOS tel launch for star/hash USSD; no carrier success guarantee.
https://drive.google.com/file/d/1ttCHtZXH3pzDt9s7yAr6ks_D_gNMAGri/view

E22 — Android recovery runbook
Current Drive source
Portable Kotlin tested historically; host not registered/compiled; marker storage is not token storage; lost installation needs server authority.
https://drive.google.com/file/d/1_kbo1JLlGEprI6QYIqdV0arMm2xJVSlG/view

E23 — Predict economics gate
Current Drive source
Conservative free-entry/no-debit contract pending accountable alternative approval; historical evidence preserved.
https://drive.google.com/file/d/17ycbTO5tfhGoKOFEnqrDMmIud2MmIQWJ/view

E24 — Route-state evidence register
Current Drive source
Current register has empty cells/groups; other evidence may exist in output.
https://drive.google.com/file/d/1KkJEsNxovRx5wc2t8-4IAop2kWgtyKCy/view

E25 — Build evidence bundles
Current Drive source
Current bundles array is empty; not an assertion all evidence is missing.
https://drive.google.com/file/d/1XJd-1UsYp-8CKMsBKpW5Cqs_h875Ur2T/view

E26 — Module registry
Current Drive source
Shared composition and compile-time internal-admin boundary retained; runtime/config precedence needs full guard verification.
https://drive.google.com/file/d/1kqV4YJGJ6gt1RTaLghwgLalHullsAqaD/view

E27 — Small disposition CSV
Current Drive source
Seven aggregate rows, not exhaustive per-object migration disposition.
https://drive.google.com/file/d/1PpYe-2H6Ssj1jFJZ3SnL8PFgTq5ewxuU/view

H01 — Dated migration inventory
Current document reporting historical execution
September 25 record: 197 tables,342 functions,354 policies,198 triggers; 18 local and 18 deployed functions differ; 6 cron jobs; restore progress and 8 media originals outstanding.
https://drive.google.com/file/d/1-7B4JcFcWG3OrLUhBamPvNLURFKqU5Kl/view

H02 — Migration plan
Current document reporting historical execution
Target architecture, one-writer sequencing, preservation and behavior migration requirements.
https://drive.google.com/file/d/1qvzgD7D9aBc4NVM3ycZQF-l4sDPBjttu/view

H03 — Historical dependency remediation
Current document reporting historical execution
September 15 advisory closure and hosted startup failure; not current production/CI proof.
https://drive.google.com/file/d/1xy5Lic4pGXeSYmeLiV2Hx6xN4RdmnABB/view

H04 — Source recovery and rollback runbook
Current document reporting historical execution
Forward-only reconciliation, isolated restore rehearsal and accountable change control.
https://drive.google.com/file/d/1HCfvyfWCOdyLeLqE2nbli-19k25Ztfeq/view

H05 — QA progress evidence
Current document reporting historical execution
Dated source-bound passing and failing runs, historical owner approval and NO-GO status; counters are not current cumulative results.
https://drive.google.com/file/d/1NzhIdmIDQc_Gm6Q6t4Lk5qzkyquGhemD/view

E28 — Native folder installation check
Fresh Drive folder listing
Current listing contains android only. iOS Batch 12 is preserved in an archive, not observed installed at its intended source path.
/Google Drive/AFRICLUB/packages/features/feat_membership/native

E29 — Operator root/src installation check
Fresh Drive folder listings
Expected wrangler.console.staging.jsonc and src/console-worker.mjs not in the scoped listings; console-handler.mjs exists.
/Google Drive/AFRICLUB/cloudflare/operator-api/

E30 — Pinned tool versions
Fresh Drive source read
Current .fvmrc=3.44.9; .nvmrc=22.23.2; packageManager=npm@12.0.2. Audit Node=22.16.0 is not the web build pin.
.fvmrc; .nvmrc

E31 — GitHub workflow verification attempt
Connector read limitation
Connected read returned 404. Current CI status/branch protection/billing cause could not be verified; absence/deletion is not concluded.
https://api.github.com/repos/IKANISA1/AFRIFAN/actions/runs?per_page=5

X01 — Public reader behavior probes
Fresh isolated execution
Four exact-source synthetic cases: stale control rejected; mixed capture accepted; stale media accepted; wrong same-length media accepted. No live endpoint called.
evidence/public_reader_probe_results.json

X02 — Boundary validator probes
Fresh isolated execution
Baseline passes; adding exact current migration plan or inventory fails. Not a whole-repo CI execution.
evidence/boundary_probe_results.json

X03 — Workflow and dependency inspection
Fresh static analysis
Workflow reachability, manifest/lock agreement and versions; no dependency installation, audit or full build.
evidence/ci_static_findings.json; evidence/dependency_manifest_probe.json

R01 — Google Drive permission semantics
External primary-source research
Anyone/writer and allowFileDiscovery describe access and search discoverability separately.
https://developers.google.com/workspace/drive/api/reference/rest/v3/permissions

R02 — GitHub Actions secure use
External primary-source research
Pin external actions to full commit SHAs; least privileges and protected deployment credentials.
https://docs.github.com/en/actions/reference/security/secure-use

R03 — GitHub deployment environments
External primary-source research
Approval and deployment protections; repository source alone does not prove settings.
https://docs.github.com/en/actions/reference/workflows-and-actions/deployments-and-environments

R04 — Next.js TypeScript build behavior
External primary-source research
ignoreBuildErrors needs an independent mandatory typecheck gate.
https://nextjs.org/docs/app/api-reference/config/next-config-js/typescript

R05 — Cloudflare D1 limits
External primary-source research
10 GB paid database cap; single-thread per database; 100 bound parameters and batch execution constraints.
https://developers.cloudflare.com/d1/platform/limits/

R06 — Cloudflare D1 batch and sessions
External primary-source research
Batch rollback and session consistency within D1; no cross-database atomicity claim.
https://developers.cloudflare.com/d1/worker-api/d1-database/

R07 — Cloudflare D1 data location
External primary-source research
Africa is not a D1 database location in the retrieved documentation; location hints are not guarantees; jurisdictions chosen at creation.
https://developers.cloudflare.com/d1/configuration/data-location/

R08 — Cloudflare Access context
External primary-source research
Direct request context and private-RPC/static-assets limitations need actual deployment tests.
https://developers.cloudflare.com/workers/configuration/cloudflare-access/

R09 — Cloudflare Queue delivery guarantees
External primary-source research
At-least-once delivery requires idempotent effects and replay handling.
https://developers.cloudflare.com/queues/reference/delivery-guarantees/

R10 — Supabase backups
External primary-source research
Database backups do not include Storage object originals.
https://supabase.com/docs/guides/platform/backups

R11 — OWASP ASVS
External primary-source research
Select traceable web/API requirements; no checklist certification implied.
https://owasp.org/www-project-application-security-verification-standard/

R12 — OWASP MASVS
External primary-source research
Verify native storage, authentication, networking and platform controls on target devices.
https://mas.owasp.org/MASVS/

R13 — NIST SP 800-63B-4
External primary-source research
Manual-code authentication is not phishing-resistant; risk benchmark rather than automatic legal obligation.
https://pages.nist.gov/800-63-4/sp800-63b.html

R14 — Apple phone-link behavior (archived)
External primary-source research
Archived Apple guidance says tel strings containing star/hash are not dialed; this is a compatibility warning, not a new iPhone test.
https://developer.apple.com/library/archive/featuredarticles/iPhoneURLScheme_Reference/PhoneLinks/PhoneLinks.html

R15 — Android app signing
External primary-source research
Distinguish resettable upload keys from application signing identity before response actions.
https://developer.android.com/studio/publish/app-signing

R16 — Apple App Review Guidelines
External primary-source research
Template/content-provider submission, product-specific payment rules, privacy and release requirements.
https://developer.apple.com/app-store/review/guidelines/

R17 — Apple account deletion
External primary-source research
Account creation requires an in-app deletion initiation route; legal retention and completion communication matter.
https://developer.apple.com/support/offering-account-deletion-in-your-app

R18 — Google Play gambling and loyalty policy
External primary-source research
Product-specific review of loyalty, prizes, paid entry and value; no gambling classification asserted by this audit.
https://support.google.com/googleplay/android-developer/answer/9877032/

R19 — WCAG 2.2
External primary-source research
Accessibility test criteria including focus, reflow and inputs; human reader tests remain necessary.
https://www.w3.org/TR/WCAG22/

R20 — Core Web Vitals
External primary-source research
p75 LCP <=2.5s, INP <=200ms, CLS <=0.1; field evidence differs from Lighthouse.
https://web.dev/articles/vitals

R21 — Rwanda DPO cloud storage guidance
External primary-source research
Offshore personal-data storage requires NCSA authorization among other requirements; published July 25, 2025.
https://dpo.gov.rw/news-and-updates/news/article/cloud-storage-under-rwandas-data-protection-law-what-you-need-to-know

R22 — Zambia DPC registration
External primary-source research
Official controller/processor registration materials; applicability and cross-border obligations require case review.
https://www.dataprotection.gov.zm/registration/

R23 — Cloudflare Hyperdrive/PostgreSQL option
External primary-source research
Workers can connect to PostgreSQL; fallback architectural option, not an approved change to target migration.
https://developers.cloudflare.com/hyperdrive/examples/connect-to-postgres/

R24 — Android Keystore
External primary-source research
Platform key policy and hardware-backed behavior require actual device verification.
https://developer.android.com/privacy-and-security/keystore